Fiche 2 : l'upload de fichier

Beaucoup d'applications permettent d'envoyer un fichier : une photo, un document, un fichier de configuration. Si le serveur ne vérifie ni le type ni le nom du fichier, on peut lui envoyer autre chose que ce qui est prévu, par exemple un script.

Le danger devient réel quand le serveur exécute ensuite ce fichier : le script tourne alors sur le serveur, avec les droits de l'application.

Ce qui peut aider

- Un script shell est un simple fichier texte qui contient des commandes, une par ligne. Il se lance avec `sh nom_du_fichier`.
- Quelques commandes de base : `ls` liste les fichiers du dossier, `cat` affiche le contenu d'un fichier, `pwd` donne le dossier courant.

Comment s'en protéger

N'accepter que les extensions attendues, renommer les fichiers reçus, et ne jamais exécuter un fichier envoyé par un utilisateur.